

C&S Wholesale Grocers, Inc. and Subsidiaries

Policy Title: Threat and Risk Assessment Policy
Status: Active
Policy Owner: IS Security and Compliance
Original Issue Date: 08/15/2011

SOP# CSISSD002
Version: 3.0
Department: IT
Last Review: 11/24/2025

Document History

Document Revision	Reviewer	Description of Changes	Date
1	Diptanil Paul	Annual Review	07/30/2022
2	Sarah Ward	Document History table added Table of Contents added	3/23/2023
3	Diptanil Paul	Annual Review	08/01/2023
4	Sarah Ward	Added Section 4 – IS Threat and Risk Exception\Acceptance	7/15/2024
5	Diptanil Paul	Annual Review	09/25/2024
6	Diptanil Paul	Annual Review	11/24/2025

C&S Wholesale Grocers, Inc. and Subsidiaries

Table of Contents

Document History	1
1. Purpose.....	3
2. Management Responsibilities	3
3. IS Threat and Risk Assessment Policy	3
Figure 1 – Risk Matrix	5
Figure 2 – Risk Matrix Severity	6
4. IS Threat and Risk Exception\Acceptance	6
5. Roles and Responsibilities	8
6. Definitions.....	8
7. Related Documents	8

C&S Wholesale Grocers, Inc. and Subsidiaries

1. Purpose

Information Services (IS) shall evaluate Company systems and the network for threats and vulnerabilities in order to protect IS assets and reduce/eliminate risk. This document describes the processes for identifying potential threats to the Company's information technology assets and assessing threats on the basis of probability and risk. The objectives are to:

- Establish a measurement method to identify IS risks that may affect business operations.
- Identify and remediate potential IS threats that could compromise systems; jeopardize Company profitability or reputation; or expose the Company to civil/criminal liability.

2. Management Responsibilities

It is the manager's responsibility to ensure that his/her direct-report employees, interns, contractors, and/or third-party workers are aware of, and agree to abide by, the Company's Information Security requirements.

3. IS Threat and Risk Assessment Policy

In order to prepare for threats to its assets and infrastructure, IS must be aware of the types of threats that exist, the likelihood that they will occur, their potential impact, and the risk these threats may pose to the Company.

3.1.1. Types of Threats

Threats may be natural or manmade. Natural threats include floods, storms, and earthquakes. Examples of manmade threats include use of unauthorized hardware or software and having unauthorized access to Company systems. Manmade threats may pose an accidental or intentional risk. For example, a programmer altering production code to fix a problem might inadvertently cause a cascading failure of major systems. Or a disgruntled programmer might deliberately sabotage a system to cause harm to The Company. Intentional threats are not confined to IS, but may also arise from external sources.

3.1.2. Threat Risk

The risk posed by any given threat is a function of the combined likelihood of the threat occurring and the impact it would have on the Company's assets (hardware, software, data, network/infrastructure, and personnel) if it were to occur. While most risk to Company assets cannot be completely eliminated, IS must make all reasonable efforts to minimize it. Those efforts begin with assessing threats and risks.

3.1.3. IS Threat Assessment Preparation

In advance of conducting a threat assessment of any of the Company's IS systems, the IS Senior Management team along with the Solver Group responsible for the system, shall establish a baseline for assessment, identifying systems to be assessed (Accounting, HR, Sales, Procurement, Transportation, Warehousing, and other systems deemed appropriate) and determining their interconnectivity with other systems. Tools used in this assessment will include the IS Asset Database and network maps/diagrams.

3.1.4. Threat Identification

The IS Senior Management team along with the Solver Group responsible for the system, will identify and describe threats that may target the IS assets and systems under consideration by one or more of the following means:

- Reviewing critical infrastructure components and application access logs for threat occurrences, such as unauthorized system access.
- Reviewing the IS Critical Incident Root Cause Analysis for trends and/or patterns.
- Conducting penetration testing based on approved IS funding to verify the IS network's ability to withstand intentional attempts at circumventing IS security.

C&S Wholesale Grocers, Inc. and Subsidiaries

3.1.5. Additional Information Sources

The IS Senior Management team along with the Solver Group responsible for the system, will incorporate additional information for developing the assessment baseline by routinely reviewing threat alerts and bulletins from vendors and standards organizations. Subscribing to one or more threat alert mailing lists is recommended for this purpose.

3.1.6. Threat Classification

To determine if IS needs to act on any given threat and to what extent it must act, the IS Senior Management team shall classify threats / vulnerabilities based on likelihood and impact.

3.1.7. Threat Likelihood

The likelihood of threats occurring may be categorized as:

- I - The threat is “practically impossible” to occur. For example, a company's three sites are all more than 500 miles from any ocean, so a hurricane or typhoon would not normally be a threat to the company.
- II – The threat is “not likely” to occur. The place where a company is located never had a hurricane incident.
- III – The threat could occur, or there is some indication of it happening in the past. The company location is in close proximity to an active volcano which geologists indicate could erupt at any time.
- IV – The threat is known to occur and “it has happened” in the past. For example, one or more of a company's sites is located in an earthquake zone, so an earthquake is likely to have an effect on the company; and has occurred in the past.
- V – The threat is likely or nearly certain to occur. For example, if IS does not require password access to computers or data stores, the likelihood is high that someone will eventually access and steal or compromise Company data.

3.1.8. Threat Impact

The impact of threats, in the absence of protection, and the possible or likely consequences of each. Threat impact may be classified as:

- Low – the threat may result in minimal loss of Company assets / resources.
- Medium – the threat may result in a significant loss of Company assets / resources, harm the Company's mission or interests, or result in injury to an employee.
- High – the threat may result in a very costly loss of Company assets / resources, significantly harm the Company's mission, interests, or standing, or result in serious or fatal injury to an employee.
- Critical- the threat may result in devastating loss of Company assets /resources, extreme harm to the Company's mission, interests, or standing, or result in serious or fatal injury to an employee.

3.1.9. Threat Exposure Rating or Risk Assessment

C&S Wholesale Grocers, Inc. and Subsidiaries

An exposure rating or risk assessment shall be based on likelihood and impact ratings. A risk matrix is prescribed (Figure 1), with likelihood running from low to extreme along one axis and impact running from Level 1 to Level 5 on the other axis. The resulting exposure rating / risk assessment shall be used to prioritize threats (Figure 2). Table 1 provides a baseline for classifying IS Operations Risk Severity.

Figure 1 – Risk Matrix

RISK ASSESSMENT AND PROJECT PRIORITIZATION MATRIX

	People (P)	IT Assets (A)	Environment (E)	Reputation (R)	Company Financial (F)	IS Operations Risk Severity (O)	I	II	III	IV	V
							Practically Impossible	Not Likely to Occur	Could Occur	It is known to occur	Will occur or Occurs frequently
1	First Aid Injury	Slight Damage (<\$10K)	Slight Effect	Slight Impact	Slight impact on Revenue <\$10M EBITDA <\$10K OR >4 and <5 Yr Payback	IT Risk severity Level 1	Low	Low	Med	Med	High
2	Medical treatment injury	Component level damage (\$10K- \$50K)	Minor Effect	Limited Impact	Minor impact on Revenue \$10M - \$50M EBITDA \$10K - \$50 OR >3 and <4 Yr Payback	IT Risk severity Level 2	Low	Med	Med	High	High
3	Lost time injury less than 7 days	Equipment level damage (\$50K- \$100K)	Localised Effect	Local Area impact	Significant impact on Revenue \$50M - \$100M EBITDA \$50K - \$100K OR >2 and <3 Yr Payback	IT Risk severity Level 3	Med	Med	High	High	Critical
4	Lost time injury more than 7 days	Unit level damage (\$100K- \$500K)	Major Effect	State wide Impact	Considerable impact on Revenue \$100M- \$500M EBITDA \$100K- \$500K OR >1 and <2 Yr Payback	IT Risk severity Level 4	Med	High	High	Critical	Critical
5	Multiple fatalities	Multiple Unit level damage (>\$1M)	Massive effect	National impact	Extreme impact on Revenue > \$500M EBITDA >\$1M OR <1Yr Payback	IT Risk severity Level 5	High	High	Critical	Critical	Critical

C&S Wholesale Grocers, Inc. and Subsidiaries

Figure 2 – Risk Matrix Severity

Critical	Stop work and introduce control measures immediately.
High	Preventive actions are required and a preventive action plan shall be developed and implemented as soon as possible. High-risk threats require the highest security levels and present the greatest need for immediate action, if existing security tools and techniques are inadequate.
Medium	Preventive actions are required and a plan to incorporate those actions within a reasonable time frame shall be developed.
Low	IS Management should confer with managers of affected systems to determine if preventive action is required or if risk is acceptable. Low-risk threats may require little or no response on the part of the IS Manager, Security & Compliance.

3.1.10. IS Threat Risk Assessment

The IS Senior Management team along with the Solver Group responsible for the system, shall conduct a threat/vulnerability scan of the IS network when requested by the IS Executive Staff or Senior Management. The scan will be performed using commercially available software designed expressly for this purpose.

3.1.11. Remediation

The IS Senior Management team along with the Solver Group responsible for the system and The Manager, IS Security & Compliance shall review scan results and analyze the findings in order to determine if IS needs to act on them and to what extent. Information Services (IS) Management shall develop recommendations based on information in the IS Asset database or obtained from assessment tools where relevant, summarizing and containing, but not limited to, the following information:

- Systems reviewed
- Number of threats found
- A summary of identified threats.

3.1.12. IS Budget and capital planning

The Information leadership team will use the assessment to assist in IS budget and capital planning. Information Services (IS) Management and the management team of the affected systems shall determine if preventive actions are required, in accordance with policy CSISSD001 IS Incident Management.

3.1.13. Controls

The following controls are required by this policy:

- Review of critical infrastructure components and application access.
- Review of IS Critical Incidents per CSISSD001 IS Incident Management.
- Conducting of random penetration tests.
- On demand threat / vulnerability scan and creation of a Security Assessment Report.
- Periodic review of risk assessment process.

4. IS Threat and Risk Exception\Acceptance

The following process will be followed to obtain approval for an IT risk exception.

4.1.1. Initiation

IS Security requester identifies the risk and the need for an exception to standard risk management.

4.1.2. Cybersecurity Risk Acceptance Form

IS Security requester prepares a comprehensive document outlining the details of the risk, the rationale for the exception, and any proposed mitigation measures. The document should include relevant information such as the nature of the risk, its potential impact, the reasons why standard procedures cannot adequately mitigate the risk, and any alternative controls or compensating measures.

C&S Wholesale Grocers, Inc. and Subsidiaries

4.1.3. Approval

IS Security routes the exception request to the appropriate business approver for approval.

4.1.4. Review and Assessment

After business owner approval, then the exception routes to IS Security leadership. The exception will be reviewed carefully, considering the information provided and assessing the justification for the exception. Subject matter experts or other stakeholders may be consulted for additional information or insights into the risk and proposed exception.

4.1.5. Decision Making

Based on the review and assessment, the approvers make a decision regarding the approval of the exception. Approvals may be granted with or without conditions, or the request may be denied if the justification is deemed insufficient or if alternative solutions are available.

4.1.6. Approval Notification

The IS Security requester is informed of the decision on the exception request. If approved, the notification should include any conditions or limitations associated with the approval.

If the IS Security request is denied, the reasons for the denial should be communicated to the requester along with any suggestions for addressing the risk through alternative means.

4.1.7. Documentation and Record Keeping

The approval decision, along with any supporting documentation and communication, is formally recorded and retained for future reference. This documentation ensures transparency, accountability, and compliance with internal policies and regulatory requirements.

4.1.8. Implementation and Monitoring

If the exception is approved, the IS Security requester implements any agreed-upon mitigation measures and monitors the risk closely to ensure that it remains within acceptable levels. Regular monitoring and reporting may be required to track the effectiveness of the mitigation measures and to identify any changes in the risk landscape over time.

C&S Wholesale Grocers, Inc. and Subsidiaries

5. Roles and Responsibilities

Please refer to the Information Security Glossary.

Role	Responsibility
Manager Information Services Security & Compliance	The Manager IS Security & Compliance is responsible for conducting threat assessments of the IS network and reporting on the results of such assessments. He or she is also responsible for monitoring threats and taking actions to mitigate risk to IS assets.
Information Services (IS) Management	IS Management is responsible for evaluating the results of threat assessments, assessing the level of risk to various Information Services assets, and recommending actions that mitigate risk.

6. Definitions

Term	Definition
Risk	The potential for an unplanned event involving a failure or misuse of IS resources to threaten business operations.
Threat	Expression of intent to cause a failure or misuse of enterprise IS resources; potential violation of security.
Threat Assessment	A process of identifying types of threats an IS network might be vulnerable to and where the network is most vulnerable.
Vulnerability	A flaw or weakness in a system's design, implementation, operation, or administration that could potentially be exploited for nefarious purposes.

7. Related Documents

- CSISAD002-01D IS Network Diagrams
- CSISSD001 Incident Management Policy
- Cybersecurity Risk Acceptance Form